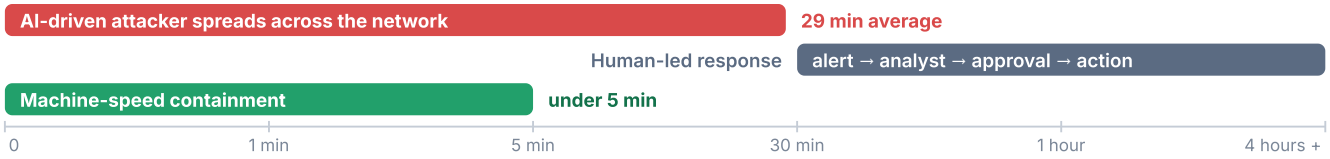
EXECUTIVE SUMMARY

Closing the agentic gap in 90 days

FASTER
29 min
average from first foothold to spreading across the network. Fastest: 27 seconds.

QUIETER
82%
of intrusions use no malware, only stolen logins and built-in admin tools.

CHEAPER
+89%
more attacks by AI-enabled groups in one year. Agents make each attack cheap to run.



Sources: CrowdStrike 2026 Global Threat Report · IBM Cost of a Data Breach 2026

DECISION Approve automated containment for near-certain attacks. Sign policy by day 30.

Risk reduction

AN AI-DRIVEN ATTACKER...	TYPICAL TODAY	DAY 30	DAY 60	DAY 90	WHAT MOVES IT
Gets in through a VPN or firewall	🔴	🟡	🟡	🟡	Edge logins and changes triaged in minutes
Gets in with a stolen login	🔴	🔴	🟡	🟡	Phishing-resistant admin MFA, auto sign-out + reset
Steals admin passwords from a laptop	🔴	🟡	🟡	🟢	Decoy credentials, auto-isolate on theft
Switches off security tools	🔴	🟡	🟡	🟢	Log-silence alerts, EDR tamper detection
Spreads to other systems in minutes	🔴	🟡	🟢	🟢	Decoy accounts, machine-speed recon detection
Encrypts or steals data	🔴	🟡	🟡	🟢	EDR block mode, auto-isolate on ransomware prep
Takes over cloud accounts	🔴	🔴	🔴	🟡	Auto-restore logging, cut off stolen keys

🔴 Not stopped in time 🟡 Detected, human-speed response 🟢 Contained automatically or prevented

Tell the board

1. AI-driven attackers spread in 29 minutes; the average breach costs **$4.99M**.
2. This plan contains near-certain attacks in under 5 minutes, cutting the chance of a company-wide incident by **about half** (proven by simulation at day 90).
3. Automation can't touch critical systems, and every action can be undone.

What you need to do

- **Day 1** Mandate phishing-resistant MFA for admins
- **Day 14** Approve read-only access for the AI triage agent
- **Day 30** Sign the containment policy
- **Day 60** Get 15 min from each app owner to sign off servers

How you'll know it worked at day 90

< 5 min
detect to contain, live simulation

9
attack types contained automatically

> 95%
of machines with EDR blocking

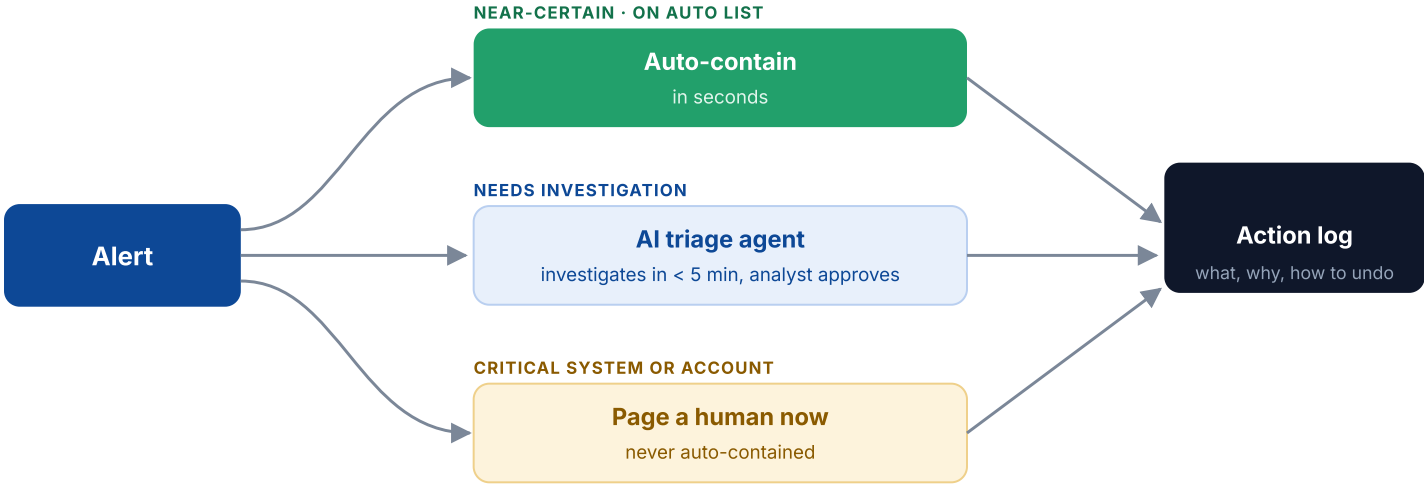
100%
of admins on phishing-resistant MFA

GUARANTEED ✓ Undo in one click ✓ Can't take down the business ✓ Clear auto / no-auto list ✓ Every action logged

ENGINEERING

How it works

Every alert takes one of three paths



The containment list

Auto

Contained in seconds when a near-certain detection fires. Starts with every workstation and standard user.

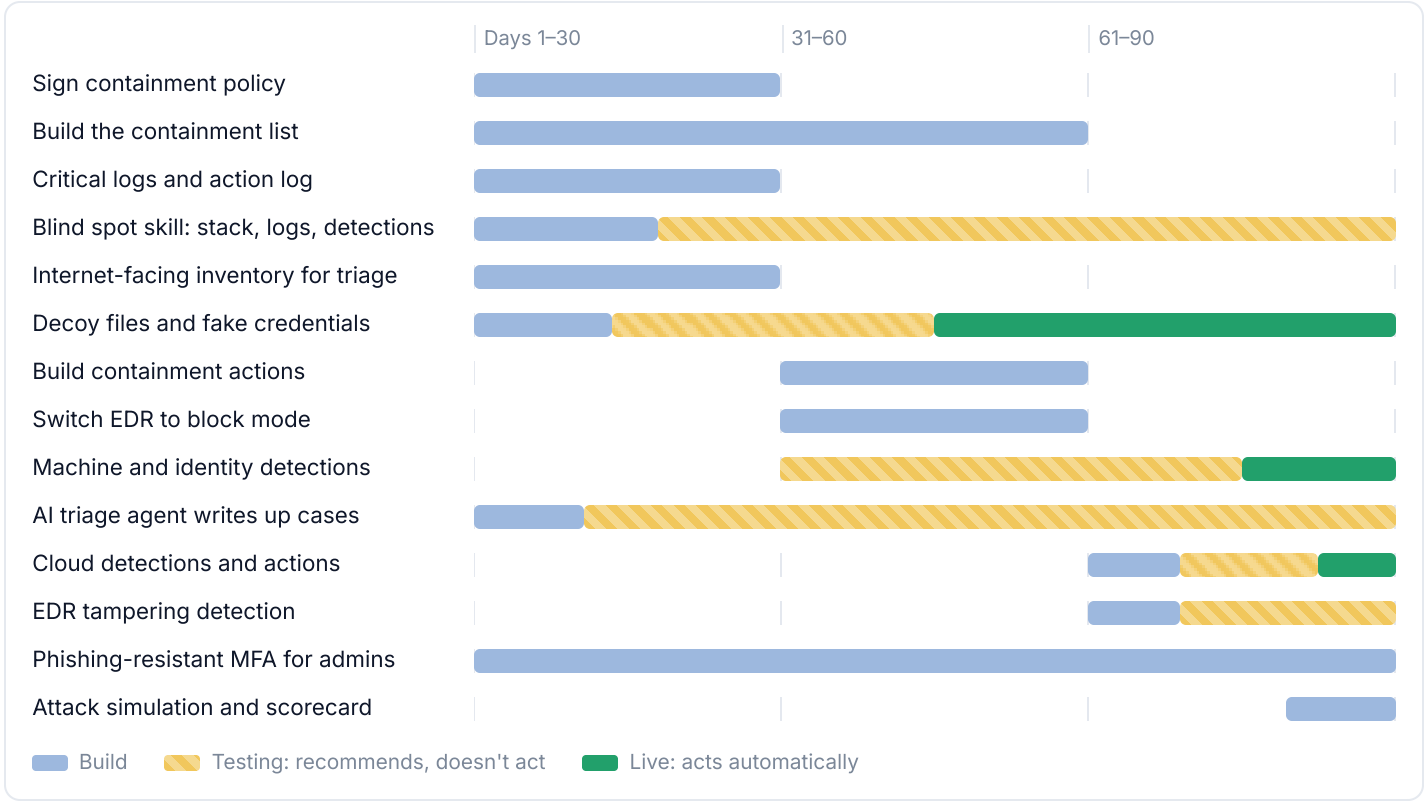
Limited

Stop the process, block the site, sign the user out, then page. Default for servers until the owner signs off.

Human only

Domain controllers, hypervisors, identity, backup, security tools, break-glass and root accounts.

90-day timeline



ENGINEERING

To-do by phase

Days 1–30 · see, investigate, authorize

- [ ] Run the blind spot skill: record the tech stack, then check logs and detections against it
  - [ ] EDR, SIEM, identity, cloud, edge, automation
  - [ ] Map each to the logs and detections it needs
  - [ ] Gaps reported with an owner
  - [ ] Later: verify the stack against the wiki / CMDB
- [ ] Get critical logs into the SIEM: under 5 min delay, alert if any go silent
  - [ ] EDR alerts and telemetry
  - [ ] EDR sensor health + a second "host alive" source
  - [ ] EDR console audit (policy, exclusions)
  - [ ] Identity sign-ins, including MFA
  - [ ] Identity audit and risk detections
  - [ ] Domain controller security logs
  - [ ] Edge device admin logins and config changes
  - [ ] Cloud control plane and threat findings
  - [ ] Decoy file read auditing
- [ ] Stand up the triage agent, read-only: it investigates high alerts and writes up the case; analysts act
- [ ] Build an internet-facing systems inventory the triage agent uses: vendor, version, owner, exposed services
- [ ] Send edge device admin logins and config changes to the triage agent
- [ ] Deploy decoys in testing mode, each with its trigger
  - [ ] Decoy files: a program opens one to read it (ignore AV, backup, indexing)
  - [ ] Fake credentials: any sign-in attempt that uses them
  - [ ] Decoy AD accounts: any logon or Kerberos ticket request
  - [ ] Once live: isolate the machine, sign out its user
- [ ] Draft the containment policy in week 1; get it signed by day 30
- [ ] Put every workstation and standard user on the auto list; servers start as limited
- [ ] Define human-only accounts by rule, checked live before any action
  - [ ] Admin roles and groups (IdP, AD, cloud)
  - [ ] Non-human: service, sync and workload accounts
  - [ ] Break-glass and cloud root: a short fixed list
- [ ] Stand up the action log: help desk can see why a user or machine was contained, and undo it
- [ ] Start phishing-resistant MFA rollout for admins

Exit: first blind spot report · triage agent writing cases · policy signed · action log live

ENGINEERING

To-do by phase, continued

Days 31–60 · build actions, learn the noise

- [ ] Add safety to every action: list check, one-click and bulk undo, rate limits that page on-call
- [ ] Call the EDR's built-in isolate and kill-process actions from automation, with the safety checks
- [ ] Build and test: block a domain or IP at DNS, proxy or firewall
- [ ] Build and test: sign out everywhere, disable account, reset password and MFA
- [ ] EDR on 95%+ of machines in block mode with anti-tamper; review exclusions
- [ ] Switch decoys to live; if they fire on more than 3 machines in 15 min, stop auto-isolating and page
- [ ] Testing mode: credential theft, MFA fatigue, machine-speed recon, ransomware prep
- [ ] Triage agent recommends actions on every testing-mode detection; analysts approve or reject
- [ ] Weekly: review each false positive; fix the rule or exempt that exact host, program and account, with an owner and end date
- [ ] Ask each server owner: can we isolate this server automatically? No answer stays limited

Exit: every action run and undone on a test target · decoys live · every high alert investigated

Days 61–90 · cloud, go live

- [ ] Cloud: revoke stolen credentials safely; auto-restore disabled logging
- [ ] Cloud detections: logging turned off, keys used outside the cloud, new admin or root use
- [ ] EDR tampering: act only with a second signal; test the outage circuit breaker
- [ ] Inventory AI agents that can send, change or run code
- [ ] Review each tested rule; switch the ones that pass to live
- [ ] Let the triage agent act on workstations for actions it got right in 95%+ of 30 cases
- [ ] Phishing-resistant MFA on 100% of admins
- [ ] Run the attack simulation; record detect-to-contain time

Exit: 9 detections live · detect-to-contain measured · scorecard to CISO

ENGINEERING

Detections, actions, thresholds

Detection → response

DETECTION	RESPONSE	DAY 90
Decoy / fake credential touched	isolate · sign out	AUTO
Decoy AD account used	isolate source	AUTO
Credential theft	isolate · sign out · reset · block C2	AUTO
MFA fatigue → approve	sign out · remove new MFA · reset	AUTO
Recon burst (≥ N cmds / 60 s)	isolate workstation · sign out	AUTO
Ransomware prep	isolate · disable · block	AUTO
Cloud logging disabled	restore logging · revoke cloud creds	AUTO
Cloud keys used outside provider	revoke cloud sessions · page	AUTO
EDR tamper + 2nd signal	sign out · isolate · page	AUTO
EDR tamper alone	triage decides	RECOMMEND
EDR high / critical	triage	RECOMMEND
Risky sign-in	triage · sign out / reset	RECOMMEND
New MFA method / help-desk reset	triage · remove method	RECOMMEND
Server spawns shell	triage · isolate / kill	RECOMMEND
New admin, root / break-glass use	triage · revert	RECOMMEND
Edge admin / config change	triage · disable admin · block IP	RECOMMEND
Prompt injection in evidence	human decides	HUMAN

Cloud: action by identity type

People

revoke sessions · deactivate key · deny-all

Workloads

revoke sessions

Workload gets fresh credentials; the attacker's copy dies.

Root · break-glass · org admin

page only

Disabled logging is always restored.

Thresholds to configure

Testing period: ≥ 2 weeks per rule

Go live when: ≤ 1 false positive / month, fired once

AI agent acts when: 30 cases · ≥ 95% agree · 0 harmful

Rate limits: per rule + per action → stop + page

EDR outage breaker: > 2% sensors silent / hour → no auto

Decoy mass-hit pause: > 3 machines / 15 min → stop auto, one incident, page

Not on the list: treat as limited

Exceptions: narrowest match · owner · ≤ 12 months

Targets come from: alert fields only, never free text

Auto actions: only on the auto list